

AAA (Authentication, Authorization, Accounting)

Task 1 — Write a short scenario where a user tries to access a private WiFi network (like at a campus or airport), and describe how each of the three AAA functions would apply step by step.

Ms.xyz arrives at her college campus and opens her laptop to connect to "Campus-Secure", the college's private WiFi network. The connection is handled in three stages:

Step 1 — Authentication: Ms.xyz's laptop connects with the nearest access point and is prompted for her college network ID and password. The access point acts as the Network Access Server (NAS) and forwards these credentials to a central RADIUS (Remote Authentication Dial-In User Service) server. The RADIUS server checks them against the student database in Active Directory. Since the credentials match a valid student record, Ms.xyz is authenticated.

Step 2 — Authorization: Once authenticated, the RADIUS server checks xyz's profile and finds she is registered as a "Student" (not staff or guest). It returns an authorization response to the access point that places her on the Student VLAN, allows access to the library portal, LMS, and general internet, but blocks access to the staff file server and admin systems. A bandwidth cap and time-of-day restriction (e.g. WiFi disabled 1 a.m.–5 a.m. in hostels) may also be applied at this stage.

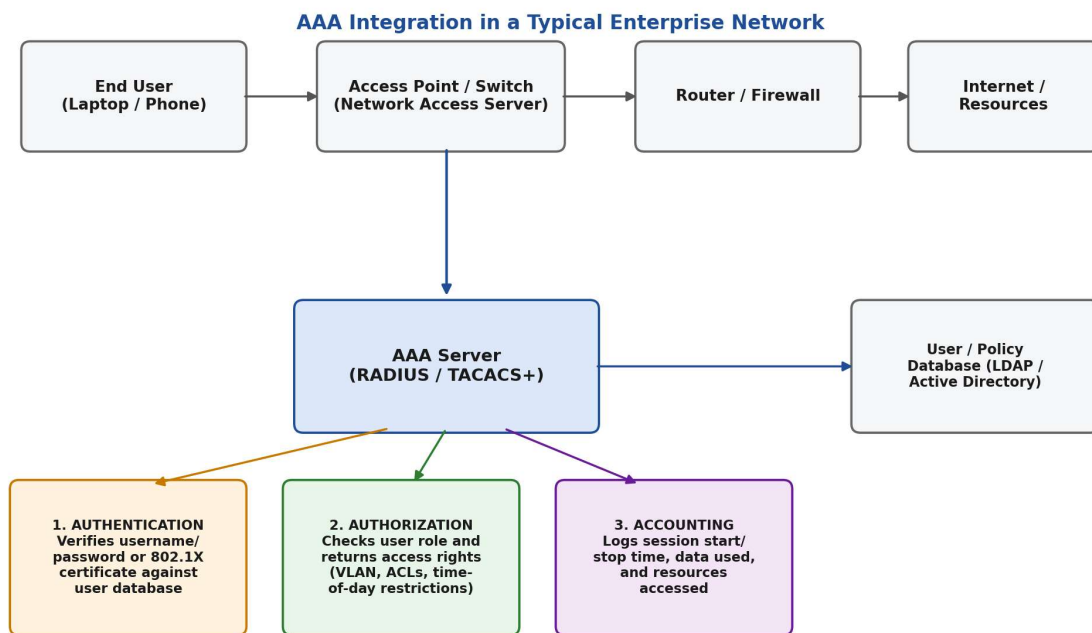
Step 3 — Accounting: The RADIUS server logs the start time of xyz's session, her assigned IP address, the access point she connected through, and continues to log how much data she uses. When she disconnects (or her session times out), a stop record is logged with the total session duration and data consumed. These accounting records let the IT department investigate misuse, monitor network load, or produce usage reports if required.

Task 2 — Create a table comparing at least two different AAA deployment models (centralized vs distributed), listing three advantages and three disadvantages of each for a company like Zomato that handles sensitive user data.

	Centralized AAA Model	Distributed AAA Model
Description	A single central AAA server (e.g. one RADIUS/TACACS+ cluster) handles authentication, authorization, and accounting requests for every branch and data center.	Each region, city office, or data center runs its own local AAA server, which may periodically sync policy with the others.
Advantages	1. One place to update security policy across all offices. 2. Simplifies compliance auditing — all logs sit in one system. 3. Lower hardware/licensing cost to maintain.	1. No single point of failure — an outage in one region doesn't lock out others. 2. Lower authentication latency for local users. 3. Scales more easily as new cities/regions are added.
Disadvantages	1. Single point of failure — if the central server or its link goes down, login stops everywhere. 2. Higher latency for offices far from the data center. 3. Central server becomes a high-value target and a performance bottleneck as Zomato scales.	1. Harder to keep security policy consistent across all servers. 2. More complex to manage, patch, and monitor many servers. 3. Higher total infrastructure and admin cost.

Which fits Zomato – Since Zomato operates across many cities and handles sensitive data (payment details, addresses, order history), a hybrid approach is realistic in practice — a distributed set of regional AAA servers for low-latency logins, with policy centrally managed and synced, so it gets the resilience of a distributed model without losing consistent security control.

Task 3 — Draw a simple network diagram showing how AAA servers are integrated into a typical enterprise network for user access control, labeling where Authentication, Authorization, and Accounting processes happen.



Task 4 – Pick any app you use daily and write a paragraph explaining how AAA concepts could be applied to secure user logins and actions within that app.

In GPay, Authentication happens every time a user opens the app and enters their mobile number with an OTP, or unlocks it with a fingerprint/PIN — this confirms the person using the app is really the account owner.

Authorization then determines what that authenticated user is allowed to do: a user with a verified KYC profile is authorized to send money and use the wallet up to RBI-mandated limits, while an unverified user might only be allowed to view balances or make small restricted transactions. Sensitive actions, like adding a new bank account or raising the transaction limit, may trigger a second authorization check such as re-entering the UPI PIN.

Accounting covers everything logged in the background: every login attempt, every transaction amount, timestamp, device ID, and location is recorded. This transaction history is what a user sees in their passbook, and it's also what Paytm's fraud-detection and billing systems rely on to flag suspicious activity or resolve a disputed payment.

Task 5 — Use ChatGPT or any AI tool to generate a sample AAA policy for a college WiFi network that restricts access to students only, allows certain websites, and logs all access attempts. Paste the generated policy and briefly explain how each AAA function is addressed.

College WiFi AAA Access Policy — "Campus-Secure"

1. Authentication

- All devices must connect via WPA2-Enterprise (802.1X). - Credentials = college ID + password, verified against the student directory access protocol (LDAP). - Non-student devices (guests, staff-only accounts) are rejected unless registered separately. - 3 failed login attempts within 10 minutes locks the account for 15 minutes.

2. Authorization

- Authenticated students are placed on the "Student" VLAN with internet access. - Allowed sites: LMS, library databases, exam portal, general web browsing (HTTP/HTTPS). - Blocked: torrenting/P2P ports, gambling and streaming sites, admin/staff-only servers. - Bandwidth capped at 5 Mbps per device during class hours (9 a.m.-5 p.m.).

3. Accounting

- Every login attempt (successful or failed) is logged with timestamp, username, and device MAC address. - Session duration and total data consumed are recorded per user. - Logs are retained for 90 days and reviewed weekly for unusual patterns (e.g. one account logging in from many locations at once).

How each function is addressed: Authentication is handled through 802.1X login against the LDAP student directory, so only verified students get on the network. Authorization is enforced through VLAN placement and a website/content filter that restricts non-students and limits which sites and how much bandwidth a student can use. Accounting is satisfied by logging every access attempt, session length, and data usage, which is exactly what's needed to trace misuse or resolve a dispute later.